

aceiii.online. 1.0 보안 취약점 점검 보고서

정적·구성 검토 | 2026년 8월 5일 | 코드 및 설정 변경 없음

요약

점검 결과, 즉시 대응이 필요한 치명적 위험 3건을 포함해 총 9건의 개선 항목을 확인했습니다. 가장 큰 위험은 LAN에서 인증 없이 접근 가능한 Edge API와 저장소에 하드코딩된 데이터베이스 자격증명입니다. 이 두 문제는 고객 데이터 노출, 거래 위변조 및 운영 환경 침해로 이어질 수 있습니다.

위험도	건수	즉시 조치
Critical	3	네트워크 격리, 인증/권한 적용, 자격증명 회전
High	2	해시 미러 제거 및 Next.js 업데이트
Medium	4	토큰·비밀번호 저장 및 오류/헤더 정책 개선

우선 대응 순서

- Edge API를 외부/LAN에서 격리하고, 모든 라우트에 강한 인증과 역할 기반 권한 검사를 적용합니다.
- 노출된 데이터베이스 비밀번호를 즉시 교체하고 Git 이력에서도 제거한 뒤 비밀번호 관리 체계로 이전합니다.
- 사용자 비밀번호 해시의 오프라인 미러와 무제한 로그인 시도를 제거하거나 강하게 보호합니다.
- Next.js를 지원되는 보안 패치 버전으로 올리고 URL 토큰과 원문 비밀번호 저장을 제거합니다.

상세 발견 사항

위험도	발견 사항과 영향	권고 조치
Critical	인증 없는 Edge API: 기본적으로 모든 네트워크 인터페이스에 바인딩되고 광범위한 CORS가 설정되어 있습니다. 판매 작성, 동기화 실행, 오프라인 상태 미러 데이터 조회가 무인증으로 가능해 LAN 공격자가 데이터를 읽거나 업무 흐름을 조작할 수 있습니다.	기본 바인딩을 로컬 또는 사설망 허용목록으로 제한하고, 전 라우트에 인증·권한 미들웨어와 요청 제한을 적용합니다. 민감 엔드포인트는 서비스 간 인증으로 별도 보호합니다.
Critical	오프라인 판매 신원 위변조: 판매자 식별이 요청 본문, 서명 검증 없는 토큰 payload 또는 헤더 값에 의존합니다. 임의 사용자를 사칭한 거래가 동기화 대기열에 들어가 이후 서버로 전송될 수 있습니다.	서명·만료·발급자·대상 검증을 통과한 세션에서만 신원을 결정하고, 요청 본문과 헤더의 사용자 식별값을 신뢰하지 않습니다. 서버 측 감사 추적을 추가합니다.
Critical	Git 추적 파일에 실제 형태의 데이터베이스 비밀번호가 반복 저장되어 있습니다. 저장소 접근자, 백업 또는 과거 커밋 노출이 운영 DB 침해로 이어질 수 있습니다.	즉시 비밀번호를 회전하고, Git 이력에서 비밀을 정리합니다. 환경 변수 또는 비밀번호 관리 서비스로 이전하고 사전 커밋 비밀 탐지와 최소 권한 DB 계정을 적용합니다.
High	사용자 비밀번호 bcrypt 해시가 Edge 미러에 저장·제공되며 오프라인 로그인에 속도 제한과 잠금 정책이 없습니다. 무인증 미러 조회와 결합하면 해시 탈취 후 오프라인 크래킹 위험이 있습니다.	비밀번호 해시를 Edge 미러에서 제거합니다. 불가피하면 암호화·접근통제·짧은 보존 기간을 적용하고 로그인 rate limit, 지연, 잠금 및 모니터링을 추가합니다.
High	사용 중인 Next.js 13.3.2는 알려진 middleware authorization bypass 영향 범위에 포함됩니다. 현재 middleware 용도가 제한적이라 직접 영향은 확인되지 않았지만 버전 자체는 취약합니다.	최소 13.5.9 이상, 가능하면 현재 지원되는 보안 패치 버전으로 업데이트하고 인증 결정을 middleware 단독에 의존하지 않도록 서버 측에서도 재검증합니다.
Medium	디자인 편집 bearer/capability token이 URL 쿼리에 포함됩니다. 브라우저 기록, 리퍼러, 로그, 공유 링크·스크린샷에서 유출될 수 있습니다.	단기·일회성 코드 교환 뒤 HttpOnly, Secure, SameSite 쿠키 또는 인증 헤더로 전환합니다. URL·프록시 로그에서 민감 쿼리를 마스킹합니다.

위험도	발견 사항과 영향	권고 조치
Medium	관리자 앱이 superadmin 원문 비밀번호를 장기 보존하고, 로그아웃 후에도 유지합니다. macOS의 강화된 키체인 보호도 비활성화되어 있습니다.	원문 비밀번호 저장을 중단하고 refresh token과 생체 재인증으로 교체합니다. 로그아웃 시 자격증명을 삭제하고 플랫폼 보호 저장소를 강화합니다.
Medium	오류 응답에 내부 예외 메시지가 노출되고 로그인 실패 이메일이 로그에 남습니다. 운영 구조 및 개인정보가 노출될 수 있습니다.	외부에는 일반화된 오류 코드만 반환하고, 내부 로그는 구조화·마스킹·접근통제로 운영합니다.
Medium	애플리케이션 설정에서 CSP, HSTS, frame-ancestors, referrer 및 permissions 정책 헤더를 확인하지 못했습니다. 배포 프록시에서 설정되는지는 추가 검증이 필요합니다.	애플리케이션 또는 프록시에 명시적 보안 헤더 정책을 추가하고 배포 환경에서 실제 응답 헤더를 검증합니다.

점검 범위와 제한

정적 코드·구성 검토와 JavaScript 구문 검사를 수행했습니다. 핵심 API 및 POS 소스는 비어 있는 Git 링크 상태여서 인증 가드, 세션 및 프론트엔드 흐름을 검토하지 못했습니다. 해당 소스가 포함된 작업트리에서 재검사가 필요합니다. 로컬 npm 감사 실행 환경과 잠금 파일이 없어 자동 의존성 감사는 수행하지 않았습니다. 운영 환경의 동적 침투 테스트도 본 점검 범위에 포함되지 않았습니다.

근거 파일(대표)

Edge API 및 신원 처리: edge-agent/src/server.js, edge-agent/src/index.js | 비밀번호: .codex/config.toml, pre-deploy.sh, scripts/measure-cockpit-pool.sh | 웹 앱: tienda-app/package.json, tienda-app/next.config.js, tienda-app/src/pages/(storeld)/panel/disenio.tsx | 관리자 앱: auth_controller.dart, secure_storage.dart